Security Risk Assessment: Network Hardening

Recommendations after a data breach at a social media company

Type	Security risk assessment report
Frameworks / references	NIST SP 800-63B (Digital Identity Guidelines), defence in depth
Skills	Vulnerability assessment, network hardening, prioritising remediation
Source	Google Cybersecurity Professional Certificate, Course 3 (*Connect and Protect: Networks and Network Security*)

Situation

A social media organisation recently had a major data breach that exposed customers' names and addresses. When I inspected the network, I found four vulnerabilities:

1. Employees share passwords.
2. The database administrator password is still the vendor default.
3. The firewalls have no rules to filter inbound or outbound traffic.
4. Multi-factor authentication (MFA) isn't used.

Part 1: Recommended hardening methods

#	Method	Vulnerabilities fixed	How often
1	**Password policies** (and removing shared and default credentials)	1, 2	Set up once; enforce automatically; review each year
2	**Firewall maintenance**	3	Default-deny baseline now; review rules regularly and after any incident
3	**Multi-factor authentication (MFA)**	4 (and lowers the risk from 1 and 2)	Set up once; maintain as users join and leave

Part 2: Why these recommendations

1. Password policies. Shared passwords remove accountability: you can't tell who did what, and one leaked password exposes many accounts. A default admin password is publicly documented, so an attacker can simply look it up. Together, these give attackers an easy way into sensitive data. I recommend that the organisation:

- **Change the default database admin password immediately** and limit admin access to named individual accounts.
- **Ban shared accounts.** Every employee gets a unique login, so actions can be traced.
- Base the password policy on **NIST SP 800-63B**: favour long passphrases over complexity rules, **screen new passwords against lists of known-breached passwords**, limit failed login attempts, and require password changes only when there's evidence of compromise, not on a fixed schedule.
- **Store passwords salted and hashed** with a modern algorithm, so a database leak doesn't expose usable passwords.

These measures defend against brute-force, credential-stuffing and password-guessing attacks.

2. Firewall maintenance. A firewall with no rules isn't providing any protection. I recommend a **default-deny** rule set that allows only the traffic the business needs, both inbound and outbound (egress filtering also helps stop data from being sent out). Rules should be reviewed on a regular schedule and updated straight away when unusual traffic is detected. Rate-limiting rules also help absorb some denial-of-service traffic.

3. Multi-factor authentication. MFA requires users to prove their identity in two or more ways: something they know (a password or PIN), something they have (an authenticator app, hardware key or badge) and something they are (a fingerprint). Even if a password is stolen, guessed or shared, the attacker still can't log in without the second factor. MFA should be required first for administrators and for remote access, then for all employees. Once set up, it mainly needs ongoing account maintenance.

Reflection

None of these fixes needs expensive tooling. The breach came from missing basics. Layering identity controls (password policy plus MFA) with network controls (firewall rules) is a practical example of defence in depth.